CO2 – ASSIGNMENT 2

Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows

In an Authorized Assessment



Course Details	Student Details
Course Code: ITA1439 Course Name: Ethical Hacking Slot: A Nature: Individual Assignment Total Marks: 50	Student Name: SHAIK ARSHAD Register Number: 192425080 Department: AIML

Submitted as an individual assignment

Executive Summary

This report designs and evaluates an authorized reconnaissance framework covering multi-source footprinting, DNS analysis, competitive intelligence, data validation, hierarchical footprint traversal and approach selection. It follows the assignment lifecycle: Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate.

All target names and results in this report are illustrative, documentation-based test cases. The reserved example domain example-corp.example is used to avoid probing real organizations. No live system, real person or third-party service is tested. Commands are provided for use only against an explicitly authorized domain or a lab-owned target. Where numerical results are shown, they are labelled as simulated planning results rather than actual tool output.

Authorization and Safety Assumptions

- Obtain written authorization identifying the domain, subdomains, DNS servers, third-party services, dates, methods and rate limits.
- Use passive collection first. Active DNS queries and zone-transfer attempts are performed only when expressly permitted.
- Do not enumerate or test real individuals. Competitive-intelligence findings are used to design awareness training, not to launch phishing, vishing, pretexting or tailgating.
- Do not treat out-of-scope, personal, stale or unverified information as confirmed findings.
- Store evidence with source, collection time, scope status, confidence and redaction notes.

Q1 – Evaluate and Engineer a Footprinting Strategy (8 Marks)

1.1 Multi-source footprinting strategy

The strategy combines WHOIS/RDAP, DNS, search engines and archived public pages. Collection begins passively to reduce operational impact. Active queries are limited to approved DNS lookups and explicitly authorized validation.

Technique / source	Passive or active	Information sought	Reliability consideration
WHOIS / RDAP lookup	Passive	Registrar, registration dates, nameservers and status.	Privacy redaction and registrar proxy services may hide registrant details.
Search engines	Passive	Indexed pages, subdomains, documents and public technology references.	Indexing can be stale, incomplete or cached.
Archived pages	Passive	Historical pages, old contact details and retired technology references.	Historical content may no longer be accurate or operational.
Public documents	Passive	Metadata, department names, software references and contact roles.	Metadata may be old; personal details must be minimised.
dig / nslookup DNS queries	Active query to DNS infrastructure	A, MX, NS, TXT and other approved records.	Results vary by resolver, cache, split-horizon view and TTL.

1.2 Collection procedure and commands

1. Confirm the signed scope and record the authorized root domain and permitted subdomains.
2. Collect WHOIS/RDAP data and record the lookup service, query time and returned fields.
3. Use search operators such as site:example-corp.example, site:example-corp.example filetype:pdf and site:example-corp.example intitle:careers.
4. Review archived public pages only for the authorized domain; mark historical data as unverified until corroborated.
5. Query DNS records with dig example-corp.example A, dig example-corp.example MX, dig example-corp.example NS and dig example-corp.example TXT.
6. Use nslookup -type=A example-corp.example and corresponding MX, NS and TXT query types as an independent resolver check.
7. Normalize results, remove duplicates, label out-of-scope items and verify important facts using a second source.

Example command sequence (replace the reserved example name only with an authorized target):

```
whois example-corp.example
dig example-corp.example A
dig example-corp.example MX
```

```
dig example-corp.example NS
dig example-corp.example TXT
nslookup -type=MX example-corp.example
```

1.3 Four contrasting target profiles – prediction versus observation

Test target profile	Prediction before collection	Illustrative observation	Assessment
T1 – Well-protected	WHOIS privacy; limited public DNS; no unnecessary documents.	Registrar privacy; A/MX/NS/TXT records disclose only required services; little indexed material.	Low exposure; still validate third-party mail and hosting dependencies.
T2 – Information-leaking	Public PDFs and archived pages may reveal department names, platforms or old contacts.	Public PDF metadata and old staff role references found; current DNS remains limited.	Moderate exposure; remove unnecessary metadata and review document publishing.
T3 – Misconfigured DNS	Unexpected records, stale hosts or excessive DNS information may appear.	Illustrative stale A record and unnecessary TXT entry found; transfer not assumed.	Moderate/high configuration concern; confirm ownership and current status before reporting.
T4 – Minimal public footprint	Few indexed pages and little public metadata.	Search returns a homepage and limited records; archived material sparse.	Low observable exposure does not prove strong security; visibility is not vulnerability.

1.4 Source reliability and contradictions

- WHOIS privacy is not evidence that the organization has no public infrastructure; DNS may still reveal nameservers and mail providers.
- A search engine may show a retired subdomain while current authoritative DNS does not. Record it as historical, not active.
- A DNS resolver may return a cached record that differs from the authoritative answer. Compare resolver, TTL and authoritative source where authorized.
- A public document may mention a former vendor. Confirm current status with a second current source before treating it as an active dependency.

1.5 Changed condition: 50 subdomains and third-party services

The original strategy remains suitable in principle but must become inventory-driven. Create an approved asset list with one row per subdomain/service, owner, provider, authorization evidence and expiry. Use passive collection to prioritize assets, then perform rate-limited DNS queries in batches. Separate university-owned assets from third-party services; third-party testing requires provider permission. Deduplicate records, cache results with timestamps and maintain a change log. A central register and automated validation improve scale without broadening the authorization boundary.

Final judgment: retain the multi-source strategy, but add asset inventory, source confidence, rate limits, ownership verification and third-party consent gates.

Q2 – Build a Reliable DNS Footprinting Workflow (7 Marks)

2.1 DNS workflow

8. Verify the domain and DNS server are included in the signed scope.
9. Query A, MX, NS and TXT records using dig; record resolver, timestamp, TTL and response status.
10. Repeat selected queries using nslookup to identify resolver-specific differences.
11. Identify delegated zones and third-party mail or hosting services without probing those providers.
12. Attempt AXFR only when the authorization explicitly names the authoritative DNS server and permits zone-transfer testing.
13. Compare the observed records with the predicted configuration and classify each as current, stale, delegated, cached or uncertain.
14. Recommend least-privilege DNS configuration and retest only after approval.

Safe record-query examples:

```
dig example-corp.example A
dig example-corp.example MX
```

```
dig example-corp.example NS
dig example-corp.example TXT
nslookup -type=NS example-corp.example
```

Zone-transfer test: only after written authorization for the named DNS server, an assessor may use a controlled AXFR request such as dig @<authorized-ns> example-corp.example AXFR. Do not run this against an unapproved server.

2.2 DNS concepts affecting visibility

Condition	Effect on external view	Interpretation
Split-horizon DNS	Internal and external clients receive different records.	External results do not represent the internal network; do not infer missing internal hosts.
Delegation	A parent zone refers a child zone to different authoritative servers.	Record the boundary and owner; child-zone testing needs explicit authorization.
Caching / TTL	Resolvers may return cached data until expiry.	Compare TTL and authoritative responses; mark conflicting cached data as provisional.
Stale records	Old addresses or hostnames remain published.	Confirm whether the asset is still owned before reporting exposure.
Third-party DNS	A provider operates authoritative DNS or service records.	University authorization alone may not authorize testing the provider's infrastructure.

2.3 Six contrasting DNS cases

Case	Prediction	Illustrative result	Risk / conclusion
D1 – Secured authoritative server	A/MX/NS/TXT visible; AXFR refused.	Expected records returned; transfer refused.	Normal public DNS exposure.
D2 – Transfer allowed in lab	AXFR could return all zone records.	Lab-only AXFR returns sample host records.	High information exposure; inventory may be disclosed.
D3 – Stale A record	Old host address may remain.	Old test address returned with low/expired operational relevance.	Verify ownership and remove obsolete record.
D4 – Split-horizon	External query omits internal-only names.	External resolver returns public records only.	Expected; do not treat as complete internal map.
D5 – Delegated subdomain	Parent NS points to separate provider.	Child NS and provider MX are visible.	Document delegation; provider testing requires separate approval.
D6 – Cached mismatch	Recursive resolver may differ temporarily from authority.	Resolver returns old A record; authoritative answer is updated.	Record TTL and query both views before conclusion.

2.4 Zone-transfer risk and countermeasures

An unrestricted zone transfer can expose a broad list of hostnames, mail systems, development services and administrative endpoints. This improves an attacker’s target discovery and may reveal forgotten systems. It does not itself grant access, but it reduces reconnaissance effort and can make follow-on targeting more precise.

- Restrict AXFR to explicitly approved secondary name servers using server-side access-control lists.
- Use TSIG to authenticate zone-transfer requests between trusted DNS servers.
- Monitor and log transfer attempts; alert on requests from unexpected sources.
- Retest only with authorization and verify that an unapproved client is refused while the approved secondary still receives updates.

Redesign outcome: after ACL and TSIG controls, the unauthorized lab client should receive REFUSED or an authentication failure, while the designated secondary remains functional.

Q3 – Competitive-Intelligence Awareness Utility (7 Marks)

3.1 Modular workflow architecture

The utility collects only public organizational information, records provenance and translates it into awareness guidance. It does not contact employees, impersonate anyone or conduct phishing, vishing, pretexting or tailgating.

Module	Activity	Output
Source collector	Search job advertisements, annual reports, press releases and public organizational profiles.	Source URL/title, publication date and collected organizational fact.
Normalizer	Remove duplicates and standardize organization, date and	Clean information register.

	source fields.	
Risk mapper	Map facts to possible social-engineering themes and warning signs.	Technique and human-risk indicator.
Review and scoring	Assess freshness, reliability, sensitivity and potential misuse.	Risk rating and confidence.
Awareness recommender	Suggest training and process countermeasures.	Awareness action plan.

3.2 Search operators and source procedure

Public source	Example operator	Information to record
Job advertisements	site:example-corp.example/jobs OR site:jobs.example-corp.example	Roles, technologies, reporting lines and hiring platforms.
Annual reports	site:example-corp.example filetype:pdf annual report	Departments, business units, vendors and organizational structure.
Press releases	site:example-corp.example intitle:press release	Public events, partnerships, projects and dates.
Public profiles	site:example-corp.example team OR leadership	Published role titles and official contact channels.

3.3 Item-to-technique mapping

Illustrative public item	Possible technique enabled (risk scenario only)	Warning indicator / countermeasure
Job post mentions a cloud platform and support workflow.	Pretexting: an attacker might claim to be a vendor support person.	Verify vendor requests through a known contact; never disclose credentials or MFA codes.
Annual report lists department names and senior roles.	Phishing: tailored messages may imitate a department or executive.	Check sender domain, unexpected attachments and urgent payment/data requests.
Press release announces a new campus facility.	Tailgating: an attacker may use a public event as a false reason to enter.	Challenge unknown visitors politely; require visitor badges and escort.
Public switchboard number and support hours are listed.	Vishing: caller may impersonate IT support.	Call back using the official directory; do not share passwords or OTPs.

3.4 Test organizations and predicted risk

Test organization	Prediction	Illustrative collection outcome	Human-risk level
Rich public footprint	Many job posts, reports, releases and official profiles.	Multiple current facts about departments, technology and roles.	Medium to high; strong context for tailored deception.
Sparse public footprint	Few pages and limited reports.	Only generic contact and service information.	Low to medium; less context, but generic impersonation remains possible.
Misleading public footprint	Old pages and inconsistent role/vendor references.	Conflicting historical and current details.	Medium; false information may cause confusion and mistaken trust.

The most dangerous source is not automatically the source with the most information. A current job advertisement that reveals a specific workflow or vendor relationship can create more targeted pretexting risk than a long general annual report. Risk is based on freshness, specificity, reliability and potential impact.

3.5 Additive improvements

- Add public procurement/tender notices as a fifth source, recording contract and vendor references without contacting the vendors.
- Add an awareness countermeasure: publish a verified contact directory and callback procedure for IT, finance and facilities requests.
- Add a visitor-management reminder: badges, sign-in and escort requirements, supported by periodic staff awareness sessions.

These additions extend the existing modules without changing the overall workflow. They improve context while strengthening verification behaviours.

Q4 – Reconnaissance Data-Validation Mechanism (6 Marks)

4.1 Validation model

Each item is represented as: item ID, value, source, collection timestamp, target/asset ID, scope status, freshness, duplicate key, source reliability and confidence. Validation uses three outcomes: PASS (usable), RECHECK (recoverable through a new query or confirmation) and REJECT (out of scope or unverifiable).

Check	Rule	Outcome
Scope	Asset/domain must match the signed allowlist.	Out of scope = REJECT immediately.
Required fields	Source, value, timestamp and asset ID must exist.	Missing provenance = RECHECK; unverifiable after review = REJECT.
Freshness	Compare collection date and DNS TTL or source publication date with policy threshold.	Stale = RECHECK.
Duplication	Normalize case, hostname and record value; compare canonical key.	Duplicate = merge/reference existing item; do not count twice.
Reliability	Prefer authoritative/current sources; corroborate important facts.	Low confidence = RECHECK; unverifiable = REJECT.

4.2 Validation order

Recommended order: (1) scope, (2) required provenance, (3) normalization and duplicate check, (4) freshness, (5) source reliability. Scope is first because an out-of-scope item must be rejected before further processing. Cheap structural and duplicate checks precede deeper source verification.

4.3 Adversarial test sequences

Sequence	Input set	Predicted outcome	Reason
V1 – All valid	5 current, in-scope, sourced unique records.	5 PASS, 0 RECHECK, 0 REJECT.	All required controls satisfied.
V2 – Out of scope	3 valid in-scope + 2 records from unrelated domain.	3 PASS, 0 RECHECK, 2 REJECT.	Scope gate blocks unrelated assets.
V3 – Stale data	3 current + 2 old DNS/document records.	3 PASS, 2 RECHECK, 0 REJECT.	Refresh or corroborate stale items.
V4 – Duplicates	4 unique valid records + 3 repeated copies.	4 PASS, 0 RECHECK, 0 REJECT; 3 duplicates merged.	Duplicates do not inflate coverage.
V5 – Mixed adversarial	3 valid + 1 out-of-scope + 1 stale + 1 duplicate + 1 missing-source item.	3 PASS, 2 RECHECK, 1 REJECT; 1 duplicate merged.	Each item follows its strongest applicable rule.

These are predicted validation results for designed test inputs, not measured live collection outcomes. During implementation, compare actual counts with these expected counts and investigate any difference.

4.4 Ordering and scalability

If source reliability is checked before scope, time is wasted validating information that must later be rejected. If duplicates are not removed early, the same item may be re-queried several times. The redesigned order reduces unnecessary work while ensuring scope is enforced first.

Scale	Illustrative items	Expected handling	Efficiency control
One target	100 items	Validate all items with the ordered checks.	Manual review with a structured spreadsheet.
Ten targets	1,000 items	Scope filtering and deduplication become important.	Central asset allowlist and automated normalization.
Fifty targets	5,000 items	Manual source-by-source review becomes slow and inconsistent.	Batch processing, source timestamps, deduplication keys and exception queue.

Final design: reject scope violations immediately, retain recoverable stale/incomplete items in a re-query queue and never promote an item to a confirmed finding until provenance and reliability checks pass.

Q5 – Evaluate Footprinting of a Hierarchical Organization (7 Marks)

5.1 Hierarchical representation

The public footprint is represented as a tree. The root is the authorized parent domain; child nodes are approved subdomains, departments and documented services. A third-party service is a terminal boundary unless separate provider authorization exists.

Level	Example node	Traversal rule
0 – Root	example-corp.example	Start only if the root is authorized.
1 – Subdomain	www, mail, learning, research	Visit only names in the approved inventory or discovered through permitted passive sources.
2 – Department/service	learning.example-corp.example → LMS; research → repository	Record service relationship and source; do not probe the service without permission.
3 – Provider boundary	External email or cloud provider	Mark as third-party terminal node; stop active traversal unless provider permission is documented.

5.2 Traversal algorithm

Pseudocode:

```
queue = [authorized_root]
visited = set()
while queue is not empty:
    node = queue.pop(0)
    if node in visited: continue
    mark node visited
    if node is out_of_scope or third_party_without_permission:
        record boundary; continue
    record node, depth, source and evidence
    if node has no public child data:
        mark terminal; continue
    add only approved, in-scope child nodes to queue
```

5.3 Test structures and prediction versus observation

Structure	Predicted nodes	Illustrative visited nodes	Boundary result
Shallow: root → 3 subdomains → 2 services	6 total including root	6	All authorized nodes visited; no deeper branch.
Deep: root → a → b → c → 2 services	6 total including root	6	Depth handled; third-party leaf stops at boundary.
Irregular: root → 2 branches; one has 3 children, another has 1; one empty branch	8 total including root	8	Empty branch marked terminal; no infinite traversal.

The node counts are illustrative tree fixtures used to verify traversal logic. In a real assessment, each node count must be derived from the approved asset register and recorded observations.

5.4 Boundary and complexity analysis

- Use a visited set to avoid cycles and duplicate nodes.
- Stop at out-of-scope nodes and third-party services without written permission.
- An empty branch is a valid terminal node; record 'no public child data found' rather than treating it as an error.
- Traversal effort is approximately O(V + E), where V is the number of nodes and E is the number of parent-child links, assuming efficient visited-set membership.

A systematic traversal is more complete and reproducible than ad-hoc browsing because it records parent-child relationships, visited nodes and stop reasons. Ad-hoc collection may be faster for a tiny target but is more likely to miss branches or revisit the same service.

Q6 – Evaluate Footprinting Approaches Under Constraints (7 Marks)

6.1 Approaches

Approach	Workflow	Strength	Limitation
A – Passive OSINT	Search engines, WHOIS/RDAP, public documents and archives.	Quiet and low impact; useful for broad initial discovery.	May be stale, incomplete or absent from indexes.
B – Active DNS footprinting	Approved A/MX/NS/TXT queries using dig/nslookup; rate-limited and logged.	Current DNS view and easier technical verification.	Generates queries, can be noticed, and may show resolver-specific results.

6.2 Same-target comparison under increasing scope

The following values are simulated planning estimates for a single authorized target set. They illustrate workload and are not actual command execution measurements.

Scope size	Passive OSINT: steps / min	Active DNS: queries / min	Interpretation
1 domain	8 / 4	4 / 1	Both practical; passive gives context, DNS confirms records.
5 subdomains	20 / 10	20 / 3	DNS becomes efficient for structured record checks.
20 subdomains	55 / 25	80 / 8	Batch DNS queries scale predictably; OSINT requires source review.
50 subdomains + providers	160 / 75	200 / 20	Provider boundaries and manual verification make unfiltered active collection unsuitable; permission gates are essential.

6.3 Redundancy and engineering judgment

- Passive search results may repeat the same hostname across multiple pages; normalize and deduplicate before counting coverage.
- DNS queries may repeat identical records across resolvers; retain resolver and TTL metadata rather than treating each response as a new asset.
- A fast approach is not always better: speed without source reliability or scope control can produce unsafe conclusions.
- A quiet approach is not always better: passive indexes can be outdated and may not confirm whether a DNS record is currently published.

Recommendation for a small-scope engagement: begin with passive OSINT, then perform a small number of approved DNS queries to verify important facts. Recommendation for a large-scope engagement: use a central asset inventory, automated passive collection and controlled batch DNS queries, with rate limits, deduplication and explicit third-party boundaries. For teaching, demonstrate both approaches on lab-owned domains and compare their evidence quality.

Final judgment: use a hybrid strategy. Passive collection is the discovery layer; active DNS is the verification layer. Choose based on authorization, required freshness, scale and operational impact—not speed alone.

Q7 – Integrated Review: Diagnose, Redesign and Defend (8 Marks)

A. Diagnose the limitation (2 Marks)

Selected workflow: Q4 reconnaissance data validation. The original simple approach of checking source reliability and freshness before scope and duplicate status has two weaknesses. First, it spends effort validating records that may be out of scope. Second, duplicates can be repeatedly checked and inflate the apparent number of findings.

Evidence from the designed mixed test sequence V5: seven submitted entries include three valid items, one out-of-scope item, one stale item, one duplicate and one item with missing provenance. The expected classification is three PASS, two RECHECK, one REJECT and one duplicate merged. The main bottleneck is poor check ordering and duplicate handling.

B. Establish evaluation criteria (1 Mark)

Criterion	Measurement	Acceptance target

Scope compliance	Number of out-of-scope items accepted.	Zero.
Coverage	Unique valid in-scope items retained / valid unique inputs.	100% in designed test cases.
Efficiency	Number of expensive source checks performed.	Avoid checks on rejected and duplicate items.
Data quality	Items with source and timestamp provenance.	100% of PASS items.
Recoverability	Stale/incomplete items routed to re-query queue.	No silent promotion to PASS.

C. Propose and implement the redesign (2 Marks)

Redesigned ordered workflow:

15. Parse the record and normalize the domain, hostname and record value.
16. Check the authorized allowlist first; reject any out-of-scope asset immediately.
17. Check mandatory provenance fields; send incomplete but recoverable entries to RECHECK.
18. Deduplicate using a canonical key; merge repeated evidence and preserve source references.
19. Check freshness using collection timestamp, TTL and publication date.
20. Check source reliability and corroborate high-impact findings.
21. Promote only fully validated items to PASS and store the validation log.

Trade-off: the redesigned workflow requires a maintained asset allowlist and normalization rules. This creates setup work, but it prevents scope leakage and reduces repeated checks.

D. Validate and compare (2 Marks)

Equivalent simulated test condition: the same seven mixed entries in V5 are processed by both workflows. Counts below are predicted outcomes from the designed fixture, not measured live-system results.

Metric	Original order	Redesigned order	Result
Out-of-scope items accepted	0 if final scope check is applied; risk of unnecessary prior processing	0; rejected at first gate	Same safety result, lower unnecessary effort.
Valid unique items retained	3	3	Coverage preserved.
Items requiring recheck	2	2	Recoverable items retained for confirmation.
Duplicates counted as new items	1 possible if deduplication is late or omitted	0; duplicate merged before deeper checks	Data quality improved.
Expensive source checks on out-of-scope/duplicate entries	Up to 2 unnecessary checks in this fixture	0 after early filtering	Efficiency improved.

The redesign does not claim faster real-world execution because no live timing experiment was performed. Its demonstrated improvement is logical: it prevents out-of-scope items from reaching deeper checks and avoids treating duplicates as unique evidence.

E. Defend the final engineering judgment (1 Mark)

The redesigned workflow is preferable for repeated or large-scale assessments because it enforces scope first, reduces redundant work and preserves provenance. The original order may still be acceptable for a very small, pre-filtered dataset where scope has already been guaranteed and there are very few records. The final choice is the redesigned order because scope compliance is a mandatory safety condition and deduplication improves the accuracy of coverage reporting.

Overall Conclusion

The seven-question design establishes a repeatable, authorized reconnaissance process. Multi-source footprinting avoids dependence on a single source; DNS analysis interprets caching, delegation and split-horizon behaviour; competitive intelligence is converted into awareness guidance rather than real-world social engineering; validation prevents stale, duplicate and out-of-scope data from becoming findings; hierarchical traversal provides clear boundaries; and the hybrid approach balances quiet collection with technical verification. The Q7 redesign demonstrates why validation order matters and provides a safer, more efficient method for larger assessments.

References and Further Reading

- CO2 – Assignment 2, ITA1439 Ethical Hacking, provided assignment PDF (10 pages).
- ICANN – Registration Data Lookup (RDAP): https://lookup.icann.org/
- ISC – BIND 9 Administrator Reference Manual (DNS and zone-transfer configuration): https://bind9.readthedocs.io/
- Google Search Help – Refine web searches: https://support.google.com/websearch/
- OWASP – Web Security Testing Guide (reconnaissance and information gathering): https://owasp.org/www-project-web-security-testing-guide/